



Software Project Audit



Make our project secure and accountable

Introduction to Software Audit (Policy Perspective)

- ▶ Software Auditing is the systematic review of digital systems, data, and controls
- ▶ Focuses on governance, accountability, risk, and compliance
- ▶ It does not require technical skills or coding knowledge
- ▶ It answers a simple question:
 - ▶ “Are our digital systems safe, controlled, and accountable?”

Software/IT Audit vs Traditional Audit

▶ Traditional Audit

- ▶ Paper files and physical records
- ▶ Manual approvals and signatures
- ▶ Visible fraud and errors

▶ Cyber / Digital Audit

- ▶ Online systems and databases
- ▶ Automated decisions and transactions
- ▶ Hidden risks (data misuse, access abuse)

IT Auditing is a Policy Issue (Not an IT Issue)

- ▶ Digital systems directly affect:
 - ▶ Citizen services
 - ▶ Public funds
 - ▶ National reputation
- ▶ Cyber failures lead to:
 - ▶ Data leaks
 - ▶ Service disruption
 - ▶ Loss of public trust

Cyber risk is a governance
and leadership responsibility

What IT Auditing Looks At (High Level)

- ▶ IT Auditing reviews:
 - ▶ Who can access systems and data
 - ▶ How citizen data is protected
 - ▶ Whether vendors are properly controlled
 - ▶ How incidents are handled
 - ▶ Whether policies are implemented in practice

No technical testing required

Government Digital Assets

- ▶ **Citizen Data**
 - ▶ NID, birth registration, social safety net data
- ▶ **Government Systems**
 - ▶ Ministry portals, service platforms, databases
- ▶ **Financial Systems**
 - ▶ e-GP, digital payments, allowance distribution
- ▶ **Infrastructure**
 - ▶ Data centers, government cloud, networks
- ▶ **Third-Party Assets**
 - ▶ Vendor-managed systems and outsourced platforms

Government Threat Landscape (Policy View)

- ▶ Unauthorized access by staff or vendors
- ▶ Data leakage due to poor access control
- ▶ Weak passwords and shared user accounts
- ▶ System downtime and service disruption
- ▶ Vendor negligence or lack of accountability

Threats are not only hackers, they often arise from weak management and controls.

Cyber Laws

- ▶ Protect citizen data and digital services
- ▶ Define responsibilities for government and vendors
- ▶ Ensure accountability in case of cyber incidents
- ▶ Support legal action against misuse or negligence

Key Cyber Laws & Policies in Bangladesh

- ▶ Cyber Security Ordinance, 2025
- ▶ Personal Data Protection Ordinance, 2025
- ▶ Information and Communication Technology (ICT) Act, 2006

Cyber Security Ordinance, 2025

Category (Ordinance 2025)	Legal Sanction
Online Gambling	Up to 2 years jail or Tk 1 crore fine or both
Cyber Fraud / Financial Deception	Up to 2–5 years jail + significant fines
Cyber Deception / Forgery	Up to 5 years jail + fines
Sexual Harassment & Exploitation Content	Increased penalties with special protection for children and women
Repealed Offences	Cases under old sections are void and dismissed

Section 17–23: Core Cyber Offences

- ▶ **Unauthorised Access & Hacking (Sect. 17):**
 - ▶ Illegal entry or interference with protected systems and critical infrastructure.
 - ▶ Punishment includes 5–7 years' imprisonment and fines; may be non-bailable.
- ▶ **Gambling Online (Sect. 20):**
 - ▶ Creating or using platforms for online gambling is punishable.
 - ▶ Up to 2 years in prison and fines

Fraud & Forgery (Sect. 21 & 22)

- ▶ Cyber-based fraud, identity misrepresentation, or falsification of digital documents.
- ▶ Penalties include imprisonment and significant fines.

Section 25–26: Content-Related Offences

- ▶ **Online Harm & Sexual Exploitation (Sect. 25):**
 - ▶ Posting or sharing intimate images without consent (e.g., revenge porn, blackmail).
 - ▶ Penalties up to several years and fines; stricter when women or children are victims.
- ▶ **Religious/Communal Hate Content (Sect. 26):**
 - ▶ Content promoting hatred against groups is punishable.
 - ▶ Aimed at maintaining public order but can be problematic if vaguely defined.

Access Control & Identity Audit

- ▶ What is Access Control?
 - ▶ Access control defines who can use which system or data and what they can do.
 - ▶ Ensures that only authorized users access sensitive information.
 - ▶ Key for protecting citizen data, financial systems, and critical infrastructure.

What is Identity Audit?

- ▶ A systematic review of user accounts, roles, and permissions.
- ▶ Checks if:
 - ▶ Old accounts are disabled after staff leave or transfer
 - ▶ Users have appropriate access levels for their role
 - ▶ Vendor or third-party access is controlled and monitored

Data Audit

- ▶ What is Data Audit?

- ▶ A systematic review of data collection, storage, usage, and protection in government systems.
- ▶ Ensures data is accurate, secure, and compliant with laws and policies.
- ▶ Focuses on citizen data, financial records, and operational databases.

Key Audit Questions

- ▶ Is data classified correctly (sensitive vs routine)?
- ▶ Who owns and is responsible for the data?
- ▶ Are there controls for integrity, confidentiality, and availability?
- ▶ How is data shared with vendors or other departments?
- ▶ Is there a data retention and disposal policy?

Vendor & Outsourced IT Audit

- ▶ A Vendor / Outsourced IT Audit is the review of systems, processes, and services managed by external providers.
- ▶ Ensures that outsourced IT activities comply with laws, policies, and government standards.
- ▶ Outsourced systems still carry government data and citizen information.
- ▶ Weak vendor management can lead to data breaches, service disruption, and legal liability.
- ▶ **Senior officials** remain accountable for governance, even if IT is outsourced.

Key Audit Focus Areas for Vendors

▶ Contractual Compliance

- ▶ Are security and data protection responsibilities clearly defined?
- ▶ Are penalties and SLAs (Service Level Agreements) included?

▶ Access Management

- ▶ Do vendors have limited and monitored access?
- ▶ Are vendor accounts regularly reviewed and revoked when unnecessary?

Key Audit Focus Areas for Vendors

- ▶ **Data Handling & Security**

- ▶ Is sensitive data encrypted, backed up, and classified?
- ▶ Are vendors following data retention and disposal policies?

- ▶ **Incident Reporting**

- ▶ Are vendors required to report breaches or suspicious activities immediately?
- ▶ Are response procedures tested and documented?

Practical Audit Questions & Policy for Vendors

- ▶ Who owns the data vs who manages it?
- ▶ Does the vendor comply with legal and policy obligations?
- ▶ Are there regular audits or reports from the vendor?
- ▶ What controls ensure accountability for service failures?

IT Audit Report Template

▶ Executive Summary

- ▶ Audit Title:
- ▶ Department / System:
- ▶ Audit Period:
- ▶ Auditors:
- ▶ Overall Assessment: (e.g., Compliant / Needs Improvement / High Risk)
- ▶ Key Highlights: 3–5 bullet points summarizing major findings or risks.

IT Audit Report Template

▶ Objectives

- ▶ Purpose of the audit (e.g., review cyber controls, data integrity, digital financial systems, vendor management).

▶ Scope

- ▶ Systems, applications, and processes reviewed.
- ▶ In-scope vs out-of-scope items.

▶ Methodology

- ▶ Review of policies, contracts, logs, and access records.
- ▶ Interviews with system owners and staff.
- ▶ Review of incident reports, audit trails, and compliance documents.

IT Audit Report Template

► Key Findings

Finding No.	Issue / Gap Identified	Risk Level (High/Medium/Low)	Evidence / Observation	Impact (Operational / Financial / Reputational)
1				
2				
3				

IT Audit Report Template

► Recommendations

Finding No.	Recommendation	Responsible Party	Priority (Immediate / Short-Term / Long-Term)	Target Completion
1				
2				
3				

Executive Decisions / Action Taken

- ▶ Decisions made based on audit findings.
- ▶ Policies approved, resources allocated, or corrective measures mandated.
- ▶ Responsible authorities identified.

Mini Case Study (Bangladesh-Style Scenario)

▶ Background of the Project

As part of the Digital Bangladesh / Smart Bangladesh initiative, a government department launched an online citizen service portal to issue certificates and manage benefit-related applications. The objective was to reduce physical visits, improve transparency, and speed up service delivery.

The system was:

- ▶ Developed by a local private IT vendor
- ▶ Hosted on a government-approved data center
- ▶ Used nationwide by district and field-level offices
- ▶ Accessible to both government officials and outsourced support staff

Thank You

